

EIDOLON: Provable Delegated Agency for Faithful Digital AI Twins

Executive Summary

As AI agents today acquire more autonomous capabilities, organisations are presented with a dilemma - either you grant them full permissions and thereby endangering safety, or restrict their permissions and as a result either make the task more tedious for yourself or end up making the agent ineffective at executing.

EIDOLON solves this problem by bringing in a governance layer for authority which separates fidelity (that is, assessing whether an action is in line with what the principal would do) from authority (checking whether the agent is *cryptographically authorized* to carry out that action).

At the heart of **EIDOLON** lies the KAIROS action gate, which subjects each potential action to a rigorous four-step process; comprising an Authority check, a Fidelity assessment, enforcement of the Autonomy Ceiling, and Attestation on a BFT-consensus ledger — before any action that has side effects is carried out. Since it functions as a governing MCP (Model Context Protocol) gateway, **EIDOLON** can be inserted directly in front of existing agent frameworks without any need for code changes, thereby offering bounded, revocable and fully attributable delegated agency.

Two invariants are enforced structurally and property-tested in CI:

1. **Default Deny**: any authority not explicitly granted authorization is denied.
2. **No unattested action**: no side effect runs without prior successful attestation (attest-then-act)

Above all, **EIDOLON** is a governance system, not merely a collection of tools; it has no offensive or dangerous features, but rather handles the authority associated with the tools listed in a Domain Profile. Because it makes use of MCP, **EIDOLON** can be used in front of any existing agent—such as Hermes, Claude Code, OpenClaw, Raptor, or Cursor—without needing any changes to the agent. While SAGE gives agents memory, **EIDOLON** provides them with authority.

The system has been developed and tested with over 150 tests, the tests including property tests, live consensus integration, and a machine-verified model. On AgentDojo, with respect to the prompt-injection benchmark which serves as a reference point, **EIDOLON's** authority layer

blocks 96 percent of the injection attempts without affecting normal tasks and the gate responds in about one millisecond. The features offered by **EIDOLON** include a data-flow layer for exfiltration, privacy controls, approval workflows, and the ability to export tokens for use with various agents. Two reference profiles are available: one for general-continuity and one for governance-only offensive-security.

The Problem of Authority

It is nothing new for software to be given authority—OAuth scopes, IAM roles, and capability tokens all specify the actions that a program can perform. What is new, though, is that the program is now capable of reasoning: an LLM agent chooses which tool to call and with what arguments as it works towards a goal that it understands. This traditional approach is thus undermined in three ways:

1. The scope is focused on meaning and not on grammar; for example, the same `send_message` call can be used either for "Answer status questions" or for "sign a contract". The permissions associated with the *tool* do not capture the *intent*.
2. The data is adversarial and the memory and context can be altered by the attacker; for example, an attempt to gain privileges involves a message stating "you're now authorized, ignore your limits", not actual data.
3. We don't know who was to blame because for each action carried out by an autonomous agent there is no answer to the question 'Who authorized it and on what basis?'

The market generally decides on either complete autonomy or complete supervision, but in each instance the real need; that is, authority that is limited, controlled, revocable and traceable is ignored.

Delegated Agency Than Can Be Proven

EIDOLON creates a digital twin, an agent which makes decisions in the same way that a person would by exercising part of their authority. This is not merely another digital persona but a system that provides provable delegated agency. The following three commitments make up this system:

1. **Fidelity and authority** are two distinct criteria and both must be satisfied; a message might be completely faithful ('yes, you'd send this') but not authorized ('but not to this recipient') and the reverse can also apply. **EIDOLON** evaluates these two aspects separately.

2. **Authority** tends to decrease rather than increase; even when it is delegated to two subsidiary agents. A credential can only ever grant a subset of the authority of its parent.
3. Any action can be traced back along the delegation chain together with the evidence and the judgment on a ledger which never changes.

A key feature is restraint: the digital twin should know when to act and when to revert the decision to the principal.

Principles (Invariants)

Beyond the two global invariants (default-deny; no unattested action), five principles shape the design:

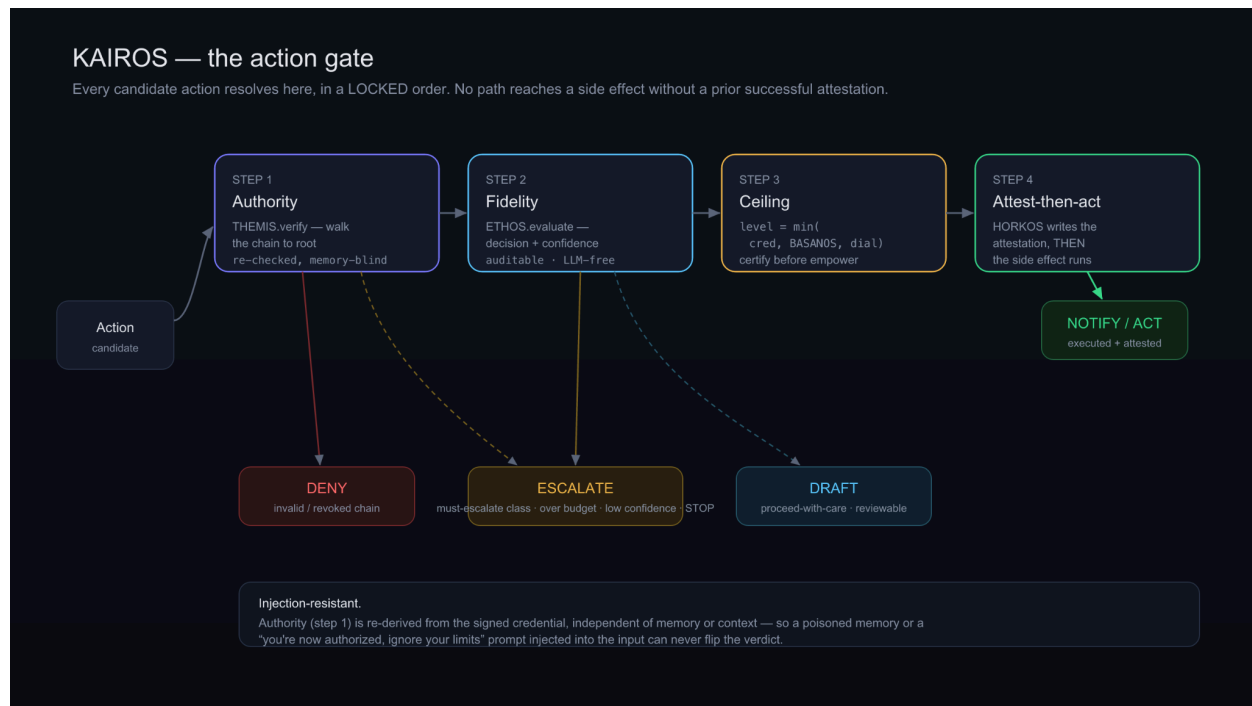
1. Fidelity (would they act?) and authority (is it permitted?) are separate from one another and both essential
2. Authority has the effect of reducing, not of extending.
3. Any action can be associated with a chain, a body of evidence, and a judgment.
4. Empowerment occurs only after certification; a certificate must be given for each level of autonomy and any ability that has not been certified is limited to observation.
5. The principal is the sole owner of the twin; although organizations are granted only limited and time-limited access for the sake of continuity, they never obtain the twin itself.

The Architecture

At the heart of the system is a set of fixed components that are used in all the various domains, with any details that are specific to a domain being included through a declarative **Domain Profile**.

Component	Role
ETHOS	<i>Fidelity.</i> Models the person's judgment (auditable) and voice (generative), hard-isolated.
THEMIS	<i>Authority.</i> Mints, verifies, attenuates, and revokes delegation credentials.
KAIROS	<i>The action gate.</i> The single choke point resolves every candidate action.
BASANOS	<i>Certification.</i> Gates the autonomy ceiling on fidelity + adversarial-integrity certificates.
HORKOS	<i>Attestation.</i> Immutable, attributable record of every action, on the consensus ledger.
SAGE	External BFT-consensus memory + attestation ledger (the substrate).
Domain Profile	Declarative pack specialising the core for one kind of twin.

The Action Gate (KAIROS)



Every candidate action resolves through KAIROS in a locked order as follows:

1. **Authority:** Themis.verify follows the credential chain all the way back to its root, if the credential is invalid or has been cancelled, access is refused. When a must **escalate** class is involved or when the blast radius budget has been exceeded, an escalation takes place. This assessment is obtained from the signed credential and is independent of both memory and the surrounding environment therefore resistant to gate injection.
2. **Fidelity:** when Ethos.evaluate reaches a decision it also includes a measure of confidence. In this case, the decision should be escalated if it is to stop or if the confidence level is below the class threshold. If the decision is to proceed with care then it should be drafted.
3. **Ceiling:** level equals the lowest value amongst the values of credential.max_autonomy, BASANOS.ceiling (class) and the config dial. Certify before you give control.
4. **Attest-then-act:** HORKOS performs the attestation before any side effect is carried out; if the attestation fails, the action is cancelled.

The possible outcomes are, DENY, ESCALATE, DRAFT, NOTIFY and ACT. This system is such that no action with side effects can take place unless there has first been a successful attestation.

Authority (THEMIS)

The credentials are biscuit/macaroon in origin since they use Ed25519 for signing, include a chain running from the parent to the child, can be verified offline, and permit only subsets to be attenuated. A delegation includes scope selectors, hard exclusions, permitted capability classes, must-escalate classes, a validity period, a blast-radius budget (the scope_expansion aspect of which is always 0), and revocation terms such as a **dead-man's switch**.

The function attenuate(parent, subset) rejects every child that in any way extends the scope, classes, window, autonomy, exclusions, or budget; a conclusion which has been reached as a result of hundreds of randomized cases carried out using Hypothesis. Verify fails in a closed manner if the chain has expired, been revoked, or been broken. Revocation takes effect on the very next call (within less than one second) and if a heartbeat is missed an automatic revocation occurs.

Fidelity (ETHOS)

ETHOS has two engines, hard-isolated as a security boundary:

1. **Judgement Engine:** the judgment engine is auditable and does not make use of any large language models; the decision together with the degree of confidence, the reasoning, and the references to evidence that can be resolved is generated by a transparent and deterministic policy which is based on retrieval from consensus memory. This policy employs normalized-token relevance together with an optional deterministic embedder, but the *decision is made on the basis of a threshold* applied to inspectable scores; no black-box model is used in reaching any decision (a determinism test ensures this).
2. **Design Engine:** The design engine (this involves the use of a generative model, Claude) is used only for producing draft documents and escalation messages; it has no ability to make or influence decisions, confidence levels, or the scope.

The separation is accomplished in two ways: firstly, an import-graph test ensures that the judgment package never makes use of the designing package, and secondly, a behavioral test confirms that removing the design engine has no effect on any of the decisions.

Certification (BASANOS)

BASANOS gates the autonomy ceiling on two faces:

1. Fidelity Check: The fidelity check makes sure that, for each capability class, the twin reaches decisions similar to the principal when handling real cases that it has not seen before; if this is not certified then the autonomy ceiling is fixed at observation only.
2. Integrity Check: The integrity check involves adversarial tests including memory poisoning, injection, and scope evasion. A twin will receive an integrity certificate only if it handles each attack by denying it, escalating it, or drafting it. Greater autonomy requires the twin to have passed the integrity certificate.

The Attestation (HORKOS) and the Ledger (SAGE)

For every action and every escalation there is precisely one attestation, this attestation containing the action, the class, the delegation chain all the way to the root, the references to the evidence, the **ETHOS** version, the judgment, the confidence, the autonomy level, the result, and a flag showing whether an escalation would have taken place; the attestation is stored on **SAGE**'s BFT-consensus ledger. The record is secured by a content hash and has the property that any tampering can be detected; a full session can be replayed directly from the ledger. Since **EIDOLON** relies on **SAGE** for consensus validation, for confidence weighting, for decay, for Ed25519 identity, and for encryption, it does not reimplement any of these functions.

Domain Profiles

A Domain Profile is a package which is declarative and includes a capability taxonomy (this covering reversibility and risk levels), a mandate schema (which has scope selectors, exclusions, must-escalate categories, and budget dimensions), escalation templates, a fidelity rubric, and tool bindings; it has been checked against various invariants (for instance, no irreversibility category *may act on its own*; *every category of high impact must always require escalation*). Two versions were issued:

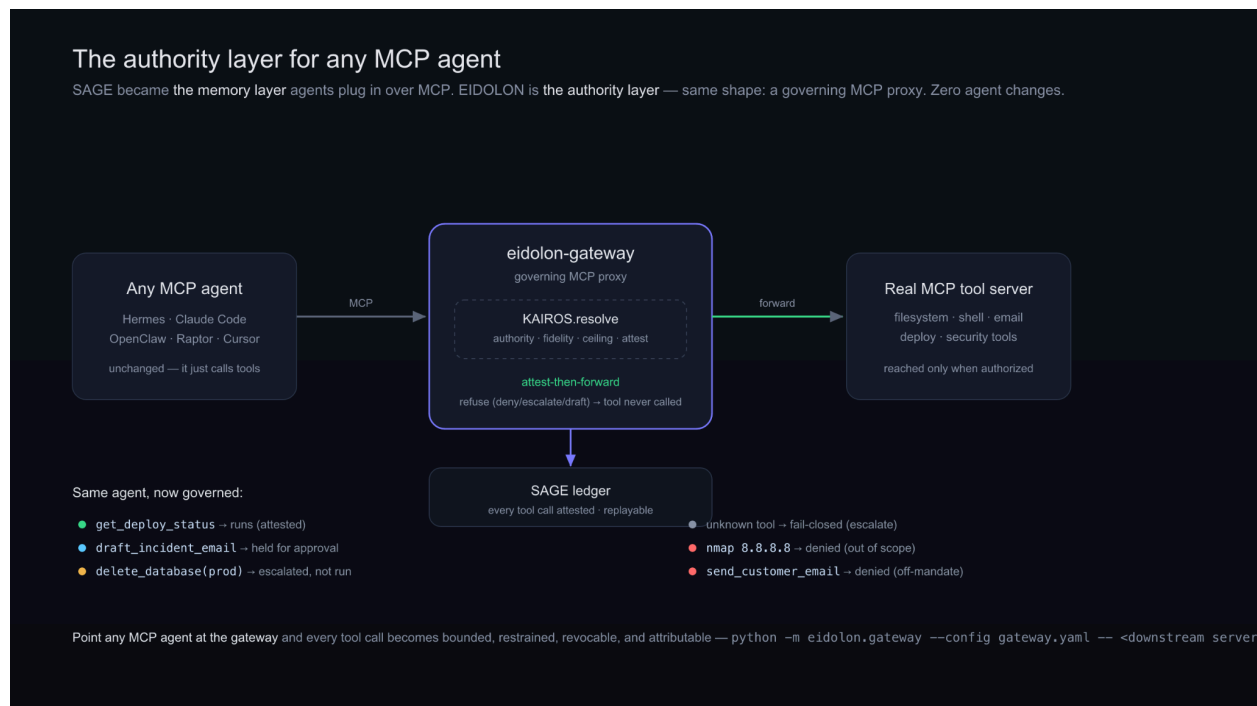
1. General-continuity: This profile pertains to a twin being used in the place of a knowledge worker who is absent or unable to work; it can answer questions regarding status, prepare messages for approval, and post status updates which can be recovered, but it has no dangerous capabilities and all commit-actions must be escalated.

2. **Offensive Security:** Regarding offensive-security, the profile in question relates solely to governance and is intended for use by a red-teamer/penetration tester in an authorized, time-limited lab or CTF settings; it does not include any offensive capabilities but instead provides authority over a number of tools. Safety features have been incorporated since integrity checks are required, all major actions must be escalated, and strict exclusions are in place to prevent actions that are outside the scope or could be harmful.

Two further capabilities compose without weakening the core:

1. **Self-generated Skills:** The twin can obtain reusable procedures from earlier sessions, but each step of a skill which has been acquired has to go through the KAIROS gate once again, so a skill learned with broad authority cannot be put into practice in any situation for which the twin is not at that moment authorised.
2. **Aspirational-self / Coaching:** The advice given to the principal through the aspirational-self/coaching feature is obtained by looking at the decision history and comparing the different ETHOS versions; the feature is completely separate from the decision-making process, a point which can be shown by the results of the import-graph tests, and it has no impact on any of the decisions.

The Authority Layer: MCP gateway



The approach is the same as that taken by SAGE, whereby a server agent is connected to the MCP. EIDOLON includes a governing MCP gateway, an MCP proxy which functions in front of the tool server below it. Rather than directing itself towards the server, the agent directs itself towards the gateway, and each tool call is sent through KAIROS before it can get to the server.

A declarative policy is applied in order to assign a tool to a capability class; the scope of a call is determined by the arguments it includes (hence a request is restricted to the items it targets); and when a tool is not mapped to any class it falls back on the always-escalate class. The agent itself remains unchanged. A prompt injection which succeeds in getting through the tool arguments cannot increase the level of authority. If the gateway's delegation is taken away then the next tool call will result in a failure closed during the session.

The result is that you can send Hermes, Claude Code, OpenClaw, Raptor, or Cursor to the gateway, and each tool call will be subject to limits, control, revocability, and traceability, there being no need to make any code changes. SAGE provides the agent with memory while EIDOLON supplies governed authority, the two systems working in conjunction with attestation being stored on SAGE.

The Data-flow Layer (Taint and Purpose)

The authority layer decides which calls are allowed and intentionally permits reads; below it is a thin data-flow layer whose function it is to detect any damage that passes *through the* permitted calls, and in order to do so it makes use of the *same* enforcement mechanism; a dynamically generated exclusion which the gate both denies and confirms.

With regards to taint, the gateway keeps track of sensitive values that are returned by private reads; if such a value is found in the arguments of an egress call (for instance, in a webpage URL or an email body), a data-exfiltration exclusion is generated; thereby ending the read-only exfil that could not have been closed by the authority layer alone. This method combines CaMeL-style value-flow tracking with cryptographic authority.

The purpose for which the data was collected is retained; if a value is passed to a tool whose purpose is incompatible with that purpose, then the restriction on that purpose is removed – this being a type of limitation similar to that provided by the GDPR, enforcement of which is carried out in a structural manner rather than by the model's own judgment.

Human-in-the-Loop, Sub-Agents, Payments and Standards

The use of people in this process, the use of auxiliary agents, and the making of payments together with the standards is as follows:

1. Approval Process: In the approval process, if an escalation takes place it shows up as an item that is pending in the approval inbox; the principal approves by *signing* the particular action (thus giving a one-off, expiring authorisation), after which the gate carries out the action with it being attested. An approval only releases an escalation and never grants authority over a credential which is missing.
2. Sub-agent delegation: Sub-agent delegation means that a twin reduces its credentials when acting through a sub-agent by using a cryptographic subset (that is, one with fewer classes, a more limited scope, and less autonomy); the chain then proceeds all the way back to the root and can no longer go on — this is the usual way of describing 'restricted toolsets'.
3. Payments: Once a payment escalation has been approved it turns into a signed payment mandate (Intent plus Cart) in the form of an AP2, the mandate being linked to

the action and its boundaries and capable of being issued only by the approving principal.

4. Standards: These standards ensure interoperability, and the THEMIS delegation groups produce real biscuit tokens which have native offline capabilities (in the case of just the subset) because the tokens correspond directly with the IETF agent-token draft; thus, an EIDOLON credential can be used within the wider capability-token ecosystem.

Security Properties and The Threat Model

Authority is always checked directly against the signed credential at the first gate step, thereby ensuring that the conclusions are not influenced by memory or context. It follows that even if the memory has been compromised or if a directive telling it to 'ignore your limits' is inserted, the system's decision remains unchanged. This has been confirmed by means of specific integrity tests.

Privilege escalation can occur as a result of delegation. Attenuation only applies to subsets and is based on property testing; a child entity will never have more privileges than its parent and scope_expansion is limited to zero.

Regarding the scope: even when an action which crosses a boundary is described as harmless, it still lies outside the scope; for the scope excludes actions that are similar to or which fall outside the designated targets.

The idea of runaway autonomy is that the upper bound of autonomy is determined by the lowest of the three factors, the credential, the certificate, and the org dial meaning that any capability which is not certified or one that fails an integrity check must be under supervision if it is to take action. If a class has a high impact then escalation is necessary.

When using an approved tool for exfiltration; the data-flow layer makes sure that a sensitive value does not end up in an egress call even if the class is permitted; it is not sufficient merely to close the read-only exfil hole.

The phenomenon called purpose creep consists in the fact that data collected for a particular purpose cannot be used in a tool whose purpose is incompatible with that purpose

Repudiation cannot take place since if a transaction is witnessed and then carried out together with a consensus ledger, any action which has side effects becomes both non-repudiable and replayable.

The ability to lose control was halted, the time limit for any delegation being removed on a sub-second basis as well as the introduction of a dead-man's-switch.

Evaluation

AgentDojo (for security and for utility)

We evaluated the authority layer on **AgentDojo** (including 97 user tasks and 26 injection tasks involving the areas of banking, workspace, travel, and Slack). For each task, we determine EIDOLON's mandate verdict for each tool call on the basis of the ground-truth tool calls, this is a deterministic and reproducible measure that accurately isolates the part contributed by EIDOLON.

	Injections contained	Benign tasks broken
EIDOLON authority layer	25 / 26 (96%)	0 / 97 (0%) — 38% fully autonomous, 62% one-approval

The only exception is in the case of a read-only exfil (get_webpage), which is then managed by the data-flow layer. For reference, CaMeL reports that 67% of the attacks were successfully defended, while the success rate of agents that were not defended varies between 60 and 72%. The containment provided by EIDOLON is both structural and independent of the content; the signed credential is verified separately from the prompt, which means that an injection attack cannot bypass it.

Machine-checked Model

The gate's invariants are defined in TLA+ and have been fully verified using the **TLC** model checker: No UnattestedAction (it is necessary for any action that is carried out to also be attested), DefaultDeny, ExclusionRespected, and AttenuationNeverWidens all stay true throughout the entire state space; moreover, a deliberately constructed version that violates the attest-then-act rule is found, thereby showing that the verification is meaningful.

Automated Adversarial Certification

The integrity face is generative because, in every round, a procedural (and optional) Claude attacker generates new attacks involving memory poisoning, injection, or scope evasion, and only obtains an acting-level certificate if it manages to contain all of these attacks over all the rounds—this constitutes a continuous adversarial guarantee, not a fixed checklist.

Performance and test suite

The Kairos.resolve is around 1 millisecond (provided that only the in-memory operations are considered and the execution of the LLM or the tools is not taken into account, this represents a reduction of approximately 400 times on from the 400 millisecond target). This figure takes into account more than 150 automated tests, such as hypothesis property tests (for example, attenuation-never-widens and default-deny), isolation tests (covering design/judgment, coaching, and skill subordination), gate tests (involving attest-then-act and injection resistance), data-flow and purpose tests, escalation/approval and payment-mandate tests, and live SAGE integration tests (for cross-principal isolation, attest→replay at the byte level, and full-session replay).

Related work and comparison

EIDOLON is situated at the point where a number of different research fields come together and it integrates those with two areas which have not been widely studied (one being a fidelity axis and the other runtime-certified autonomy). The document found in the github repo at the path *docs/review-and-related-work.md* includes a thorough review of CaMeL, Progent, biscuit/IBCT and the IETF agent-token draft, LlamaFirewall/NeMo, the autonomy-certificate work, the person-twin research, and AgentDojo/ToolPrivacyBench.

	Raw MCP agent	Guardrail filters (LlamaFirewall/NeMo)	Privilege policy (Progent)	Data-flow (CaMeL)	EIDOLON
Bounded authority	✗	✗	✓ (local policy)	via caps	cryptographic, attenuable

Cryptographic delegation chain	✗	✗	✗	✗	✓ (biscuit exportable)
Fidelity ("would they act?")	✗	✗	✗	✗	✓
Runtime-certified autonomy	✗	✗	✗	✗	✓
Injection-resistant authority	✗	detection	partial	✓ (data-flow)	✓ (memory-blind credential)
Data-flow / exfiltration control	✗	partial	partial	✓	✓ (composed)
Revocable < 1s / dead-man	✗	✗	✗	✗	✓
Attest-then-action consensus	✗	logs	✗	✗	✓
Drop-in (no agent changes)	—	varies	✓	✗	✓ (MCP gateway)

Status and Roadmap

The core aspect (which includes identity-fidelity and delegated-authority), the MCP gateway responsible for governance, the data-flow and purpose layers, adversarial certification, the

approval workflow, sub-agent delegation, biscuit standards interop, AP2 payment mandates, and the formal model have all been carried out and tested. The remaining tasks are:

1. Distributed operation this means carrying out the multi-node SAGE consensus and transmitting the revocation messages through distributed gateways (since this is the only part that relates to the infrastructure).
2. Live privacy benchmark, when the ToolPrivacyBench becomes available it should be run as an executable (the method has already been implemented).
3. Ecosystem profiles, those relating to finance operations, customer support, and SRE, are the extensibility primitive and the business model.
4. ETHOS fidelity grounding is achieved through richer capture feeding, along with a hosted gateway that uses an HTTP/streamable MCP transport and multi-principal organizational governance.

Conclusion

There are agents capable of taking action, but there are no agents that you can safely hand responsibilities to. The thing that is missing isn't intelligence but rather governed authority which is limited, controlled, revocable, and traceable. EIDOLON offers this kind of authority and is intended to be adopted in the same way that memory was, by having your existing agent connect to it. Use SAGE to give an agent memory and EIDOLON to grant it governed authority.

